CO-2 ASSESSMENT-3

SIMATS ENGINEERING

ASSESSMENT TOOL 3 – ETHICAL HACKING

Scenario-Based Assessment

This report addresses passive footprinting and competitive intelligence, DNS zone transfer testing, and social engineering phishing awareness. It is organized to align with the assessment rubric.

Ethical-use note: Perform technical tests only on domains and systems for which you have explicit authorization. Replace illustrative examples with actual evidence from your authorized lab.

Q1. Footprinting Tools – Conducting Competitive Intelligence

Aim

To perform passive footprinting on ABC Technologies by collecting publicly available information about domain registration, employee email addresses, technology stack, and publicly exposed subdomains without directly interacting with the company's servers.

Introduction

Footprinting is the first stage of ethical hacking. It involves collecting information about a target before a security assessment. Passive footprinting uses public sources such as search engines, domain registration databases, certificate transparency logs, and technology lookup services rather than actively scanning the target's systems.

Competitive intelligence is the collection and analysis of publicly available information to understand an organization's digital presence, technology choices, and potential security weaknesses. In ethical hacking, the goal is to improve security, not to exploit the organization.

Objectives

- Identify publicly available domain registration details.
- Find publicly indexed employee email addresses where available.
- Identify technologies used by the public website.
- Discover publicly listed subdomains and hostnames.
- Analyze findings and recommend security improvements.

Tools and purposes

Tool	Purpose	Information collected
WHOIS	Domain registration lookup	Registrar, registration dates, nameservers, status, and registrant details if public
theHarvester	Public information gathering	Emails, hostnames, domains, and indexed information depending on source
Google Search / search operators	Search public web content	Public contact details, documents, and indexed subdomains
crt.sh	Certificate transparency lookup	Hostnames listed in publicly issued TLS certificates

Wappalyzer	Technology identification	CMS, frameworks, analytics, and other detectable website technologies
DNSDumpster	DNS footprinting	Publicly identified subdomains and DNS-related information

Procedure

Step 1: Domain registration details using WHOIS

WHOIS retrieves publicly available domain registration information. Use the authorized target domain in place of example.com.

```
whois example.com
```

Observe the registrar, creation and expiry dates, nameservers, domain status, and registrant information if public. Privacy protection may hide registrant details. Public administrative information can support impersonation attempts, so use registrar-account MFA, secure renewal procedures, and privacy protection where appropriate.

Step 2: Email and hostname enumeration using theHarvester

```
theHarvester -h
```

```
theHarvester -d example.com -b crtsh -l 100
```

The -d option specifies the domain, -b specifies the data source, and -l limits the number of results where supported. Check the installed version's help output to confirm supported sources.

Important: crt.sh primarily provides certificate-related hostname information and may not return employee email addresses. For email enumeration, select a supported email-capable source in the installed theHarvester version.

Record the source, collection date, publicly listed email addresses, naming patterns, and discovered hostnames. Do not invent addresses or present examples as verified results.

Category	Illustrative pattern only	Security relevance
General contact	info@example.com	May be targeted with spam or impersonation
IT support	support@example.com	May be impersonated in technical-support scams
Human resources	hr@example.com	May receive fraudulent recruitment or document requests
Security team	security@example.com	May be targeted with fake incident reports
Individual employee	firstname.lastname@example.com	May be targeted with personalized phishing

Security risk: Public email addresses and naming conventions can support spear-phishing. Countermeasures include awareness training, SPF/DKIM/DMARC, MFA, and clear reporting procedures.

Step 3: Technology stack identification using Wappalyzer

1. Open the Wappalyzer website or use its browser extension.
2. Enter the authorized company's public website.
3. Review the technologies detected and record the date.
4. Verify important findings with another trusted source where possible.
5. Record the detected CMS, frameworks, analytics, and other visible technologies.

A detected technology does not automatically prove a vulnerability. Risk depends on version, configuration, exposure, and security updates. Maintain a software inventory, patch supported components, and remove unused services.

Step 4: Public subdomain discovery using crt.sh

Certificate transparency logs can reveal hostnames included in publicly issued TLS certificates.

`https://crt.sh/?q=%25.example.com`

6. Search the authorized domain and its subdomains.
7. Record relevant hostnames and remove duplicates.
8. Classify hostnames by their apparent purpose.
9. Verify findings before treating a hostname as an active service.
10. Compare results with the organization's approved asset inventory.

Illustrative hostname	Possible purpose
www.example.com	Main website
mail.example.com	Email-related service
vpn.example.com	Remote access service
dev.example.com	Development environment
test.example.com	Testing environment

These hostnames are examples only. A name alone does not prove the service's function or accessibility. Review unexpected development or testing records and restrict them where necessary.

Competitive intelligence analysis

Information	What it establishes	Potential concern
Domain registration	Domain ownership and administration details	Domain account compromise or impersonation
Employee emails	Public contact information and naming patterns	Targeted phishing
Technology stack	Technologies used by the website	Outdated software or misconfiguration
Subdomains	Publicly known hostnames	Forgotten or inadequately protected services

Recommended countermeasures

11. Protect domain registration: enable MFA for registrar accounts and maintain secure renewal procedures.
12. Strengthen email security: configure SPF, DKIM, and DMARC appropriately.
13. Manage public subdomains: maintain an accurate DNS inventory and remove unnecessary records.
14. Update software: patch supported applications, frameworks, and server components.
15. Restrict development systems using authentication and access controls.
16. Train employees through regular phishing-awareness sessions.
17. Periodically review exposed hostnames, contact details, and technology information.

Result

Passive footprinting tools can identify publicly available domain registration information, email addresses, technology details, and subdomains without directly scanning the company's servers. These findings support competitive intelligence and help prioritize security improvements.

Evidence to attach: screenshots of tool commands and actual results, with the target domain, source, date, and brief interpretation. Replace examples with verified lab findings.

Q2. DNS Zone Transfers

Aim

To verify whether an authorized target DNS server permits an unauthorized DNS zone transfer and understand how retrieved DNS records can support reconnaissance.

Introduction

DNS translates domain names into IP addresses and stores other service-related information. A DNS zone transfer copies records from an authoritative DNS server to another DNS server, commonly to synchronize primary and secondary servers. If unauthorized requesters can transfer a complete zone, hostnames, mail servers, and other DNS records may be disclosed.

Tools and objectives

- Kali Linux terminal and the dig DNS query utility.
- An authorized test domain and DNS server.
- Identify authoritative nameservers.
- Check whether a zone transfer is permitted.
- Interpret the result and recommend secure configuration.

Procedure

Step 1: Identify authoritative nameservers

```
dig NS example.com
```

This requests NS records, which identify the domain's authoritative nameservers. Replace example.com with the authorized test domain.

Illustrative output (actual results may differ):

```
example.com.  3600  IN  NS  ns1.example.com.
example.com.  3600  IN  NS  ns2.example.com.
```

Step 2: Check the SOA record

```
dig SOA example.com
```

The Start of Authority (SOA) record includes zone-administration details such as the primary nameserver, responsible-party field, serial number, and refresh settings.

Step 3: Test a zone transfer

```
dig AXFR example.com @ns1.example.com
```

AXFR requests a full DNS zone transfer. Replace the domain and nameserver with the authorized test domain and its actual authoritative nameserver. Only test systems for which you have explicit permission.

Step 4: Interpret the result

Observed result	Interpretation
Transfer succeeds and records are returned	The zone contents were transferred. If the requester was unauthorized, this may indicate an access-control weakness.
Transfer refused	The server rejected the request, generally the expected outcome for an unauthorized requester.
Timeout or other error	Inconclusive; filtering, availability, or configuration issues may prevent a clear conclusion.

A timeout alone does not prove that the DNS server is secure. Report only the outcome actually observed.

Understanding DNS records

Record	Purpose	Reconnaissance value
A	Maps a hostname to an IPv4 address	Identifies addresses associated with hosts
AAAA	Maps a hostname to an IPv6 address	Identifies IPv6 addresses
MX	Identifies mail servers	Shows where domain email is handled
CNAME	Creates a hostname alias	Reveals relationships between hostnames
NS	Identifies nameservers	Shows which servers are authoritative
TXT	Stores text data, including email-security policies	May reveal SPF or domain-verification information
SOA	Provides zone-administration information	Helps understand DNS zone configuration

How a successful transfer supports reconnaissance

18. Host identification: A and AAAA records may reveal hostnames associated with IP addresses.
19. Mail server identification: MX records reveal mail servers and support review of email-security configuration.
20. Subdomain discovery: A transfer may list web, mail, VPN, testing, and other service-related hostnames.
21. Configuration review: Unexpected or obsolete records may indicate that DNS documentation and cleanup procedures need improvement.

A successful transfer does not automatically mean that every listed host is vulnerable. It indicates that DNS information may be disclosed beyond the intended audience.

Risk analysis

Risk	Explanation	Potential impact
Information disclosure	Full zone contents may be revealed to an unauthorized requester	Greater visibility into infrastructure
Host discovery	Hostnames and IP addresses may be exposed	More detailed reconnaissance
Email infrastructure discovery	Mail servers and related records become visible	Supports targeted phishing planning
Forgotten DNS records	Old or unnecessary entries remain in the zone	Unmanaged assets may be overlooked

Countermeasures

22. Restrict AXFR requests to authorized secondary DNS servers.
23. Use access-control lists to limit which systems may request transfers.
24. Use TSIG authentication where supported and properly configured.
25. Audit DNS records and remove obsolete or unnecessary entries.
26. Log and investigate unexpected zone-transfer requests.
27. Secure DNS administration and keep DNS software updated.
28. Review zone-transfer settings during authorized security assessments.

Result

The dig AXFR command can test whether an authorized DNS server permits a zone transfer. A successful transfer may disclose hostnames, IP addresses, mail servers, and other DNS records. Access restrictions, authenticated transfers, monitoring, and regular DNS audits help prevent unauthorized disclosure.

Evidence to attach: screenshots of the NS lookup, SOA lookup, AXFR test, and a short explanation stating whether the transfer succeeded, was refused, or was inconclusive.

Q3. Social Engineering Attacks and Countermeasures

Aim

To identify an email-based social engineering attack and recommend employee actions that help prevent credential theft.

Introduction

Social engineering manipulates people into revealing sensitive information, performing unsafe actions, or granting unauthorized access. It often exploits trust, fear, curiosity, urgency, or the desire to help. The email in this scenario claims to come from IT and asks employees to verify credentials through a link because of an urgent security update. This is a common form of phishing.

Attack identification

The main attack is phishing: a fraudulent message designed to trick a recipient into disclosing information or taking an unsafe action. If the message is personalized for a particular person or organization, it may also be spear-phishing. If it impersonates a trusted authority, it may overlap with pretexting or business email impersonation.

Warning sign	Explanation
Impersonation	The sender claims to represent IT support.
Urgency	The message pressures the recipient to act quickly.
Credential request	The employee is asked to verify login details.
Suspicious link	The link may lead to a fraudulent login page.
Manipulation	Concern about account security is used to influence behavior.

How the attack works

29. Email delivery: The employee receives a message pretending to come from IT support.
30. Urgency and trust: The message claims immediate action is needed to protect the account.
31. Link interaction: The employee is persuaded to open a link to a potentially fraudulent page.
32. Credential theft attempt: The page asks the employee to enter a username and password.
33. Potential account compromise: If credentials are captured and misused, an attacker may gain unauthorized access.

The attack is not guaranteed to succeed. The outcome depends on employee actions, email security controls, and whether the attacker can misuse any information obtained.

Key security issues

- Employees may trust the display name without checking the full email address.
- Urgent wording may cause employees to bypass normal procedures.
- Fraudulent login pages can imitate genuine company websites.
- Stolen credentials may expose email, internal applications, and other services.
- Compromised accounts may be used to send further phishing messages.
- Password reuse can put additional accounts at risk.
- Successful compromise may cause data loss, financial loss, or reputational damage.

Employee countermeasures

Step 1: Verify the sender

Check the full email address and domain, not only the display name. Be cautious of misspellings, unexpected external senders, and addresses that do not match the official company domain. This can reveal simple impersonation attempts, although a familiar-looking address alone does not prove a message is genuine.

Step 2: Do not click suspicious links

Avoid opening unexpected links or attachments. If an update is mentioned, open the organization's official portal using a known bookmark or type the known official address manually. This reduces the chance of visiting a fraudulent login page or downloading malicious content.

Step 3: Never submit credentials through an unexpected link

Do not enter passwords, one-time passcodes, or other authentication secrets into a page reached through an unexpected email. Follow the organization's approved authentication process. This prevents employees from directly handing credentials to a phishing website.

Step 4: Verify through another channel

Contact IT support using the official help desk number, company directory, or approved ticketing system. Do not rely only on contact details included in the suspicious email. Independent verification helps establish whether the update is genuine.

Step 5: Report the email

Use the organization's Report Phishing feature or follow the approved process for reporting suspicious messages. Avoid forwarding the message to coworkers as a warning. The security team can investigate, block malicious links, and warn other employees.

Step 6: Check for warning signs

Look for unusual urgency, spelling mistakes, unexpected attachments, unfamiliar domains, requests for confidential information, or threats of immediate account suspension. Recognizing warning signs gives employees time to stop and verify the request.

Step 7: Follow official procedures

Use approved password-reset and account-verification processes. Do not bypass normal procedures just because an email claims an emergency. Standard procedures reduce opportunities for manipulation.

Technical countermeasures for the organization

Countermeasure	How it helps
Multi-factor authentication (MFA)	Adds another authentication layer, though it does not eliminate all phishing risks.
SPF, DKIM, and DMARC	Help authenticate legitimate domain email and reduce spoofing.
Secure email gateway	Can detect and block known malicious messages, links, and attachments.
Web filtering	Can block access to known malicious websites.
Employee awareness training	Improves recognition of phishing and reporting behavior.
Password manager	Supports unique passwords and may warn when the login domain does not match the saved site.
Incident response process	Supports prompt investigation, account protection, and organization-wide warnings.
Phishing-resistant MFA	Security keys or passkeys provide stronger protection against credential-phishing attacks.

If an employee has already clicked the link

34. Report the incident to IT or the security team immediately.

35. If credentials were entered, change the affected password through the official portal, following security-team instructions.
36. Change reused passwords on other accounts.
37. Ask the security team to revoke active sessions and investigate suspicious sign-ins.
38. Follow incident-response instructions and preserve the suspicious email for investigation.

Even if the employee only clicked the link and did not enter information, report it. The page may have attempted a download or exploited a browser vulnerability.

Risk analysis

Risk	Possible consequence	Prevention
Credential theft	Unauthorized account access	Avoid unexpected login links; use MFA
Email account compromise	Fraudulent messages sent to others	Secure authentication and monitor suspicious sign-ins
Data theft	Confidential information may be accessed	Least-privilege access and monitoring
Malware infection	A device may be compromised	Email filtering, web protection, endpoint security
Financial or reputational damage	Fraud, disruption, or loss of trust	Training, reporting, and incident response

Example of a safe response

An employee receives an urgent email asking for a password. Instead of clicking the link, the employee opens the company's official IT portal using a saved bookmark and checks whether an update is required. The employee also reports the suspicious email to the security team. This helps prevent credential theft because the request is verified independently.

Result

The email described in the scenario is a phishing attempt that uses impersonation and urgency to persuade employees to disclose credentials. Sender verification, avoiding suspicious links, independent confirmation, prompt reporting, MFA, and email security controls can substantially reduce credential theft and account compromise.

Overall Conclusion

Footprinting, DNS analysis, and social engineering awareness are important parts of ethical hacking. Passive footprinting identifies public domain, email, technology, and subdomain information. DNS zone-transfer testing helps determine whether DNS records can be disclosed to unauthorized requesters. Phishing awareness and technical controls help prevent credential theft and unauthorized account access. Together, these practices help organizations understand external exposure, identify misconfigurations, and reduce the likelihood of successful social engineering attacks.

Code of Conduct

I, _____J.VISHNU VARDHAN(192324297)_____ (Name / Reg No), certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: _____

Date: _____21/10/2026_____

Rubric Alignment Checklist

Rubric criterion	Weightage	How this report addresses it
Understanding of scenario	20%	Defines concepts and connects them to each scenario.
Identification of key issues	20%	Identifies public information exposure, DNS misconfiguration, phishing indicators, and risks.
Application of concepts	25%	Includes relevant tools, commands, procedures, and interpretation guidance.
Decision making	20%	Provides justified countermeasures and explains how they reduce risk.
Clarity of response	15%	Uses headings, tables, command blocks, and structured conclusions.

Before submission: Add screenshots from your authorized lab, insert actual outputs and findings, and ensure every claim matches the evidence. Do not report hypothetical examples as verified findings.